

EGR6301 — Етичний хакінг

Лабораторна робота 9: Підвищення привілеїв — SUID, sudo та шлях до root

find / -perm -4000 на Metasploitable 2, sudo ht на Kioptrix Level 1.2, і одна машина без інструкцій

Факультет комп'ютерних технологій та кібербезпеки • Весна 2026

Тривалість:	100 хвилин
Всього:	100 балів (трек А: 75 + трек В: 25)
Цільова машина (Трек А):	Metasploitable 2 (та сама ВМ, що у Лабораторній 8)
Цільова машина (Трек В):	Kioptrix Level 1.2 (VulnHub) https://www.vulnhub.com/entry/kioptrix-level-12-3,24/
Тип роботи:	Дворівнева: контрольована вправа з SUID/sudo + застосування проти незнайомої цілі

ЯК ПРАЦЮЄ ЦЯ ЛАБОРАТОРНА РОБОТА

Ця лабораторна робота поділена на два треки. Трек А (Частини 1–4): обов'язкова частина на 75 балів, де ви працюєте проти Metasploitable 2: знаходите SUID-бінарники з допомогою `find / -perm -4000`, ідентифікуєте серед них один штатний з зловживним патерном і один навмисно встановлений викладачем, експлуатуєте обидва через GTFOBins, аналізуєте `/etc/sudoers` через `sudo -l`, експлуатуєте знайдене правило і завершуєте роботу трьома адресними рекомендаціями для клієнта. Якщо ви якісно виконаєте Трек А, ви отримаєте оцінку в діапазоні B+ — A–.

Трек В (частина 4): додаткове завдання на 25 балів для тих, хто претендує на оцінку А. Це міні-CTF проти Kioptrix Level 1.2, де ваше завдання: застосувати техніку треку А проти цілі, для якої немає прямих інструкцій. Kioptrix 1.2 побудована навколо ланцюга «веб-RCE → база даних → SSH → SUID-редактор», і ваше завдання: пройти цей ланцюг до root.

Трек В не можна виконати, скопіювавши walkthrough з інтернету. Kioptrix 1.2 має десятки публічних walkthroughів. Ваше завдання у звіті: довести, що шлях ви пройшли самостійно, на основі даних, які може знати лише ви: точні значення MySQL-хешу loneferret, точний розмір файлу `/etc/sudoers` до і після редагування, конкретні байти, які ви замінили в HT Editor.

Трек В оцінюється лише за умови якісного виконання треку А. Якщо Трек А виконано нижче 50/75, роботу Треку В буде проігноровано.

ОБОВ'ЯЗКОВІ ПРАВИЛА ЗВІТУВАННЯ

Якщо ваш звіт містить лише вивід інструментів і скріншоти без вашого власного аналізу, ви отримаєте 0 балів за цей розділ. Кожен скріншот має супроводжуватися абзацом: «ЩО ви знайшли», «ЧОМУ це важливо», «ЩО далі».

Ви **ПОВИННІ** задокументувати щонайменше дві реальні невдачі. Першу природну невдачу легко знайти: SUID-перерахування поверне ~25 рядків, з яких більшість стандартні (passwd, sudo, su). Опишіть один із кандидатів, який ви розслідували, але виявили, що він не вразливий наприклад, /usr/bin/at, який має SUID, але без зловживної техніки на цій версії Debian. Друга невдача: на ваш розсуд: команда GTFOBins, яка не спрацювала з першого разу через відсутній прапорець; sudo -l, що повернуло порожньо для першого користувача, з якого ви тестували; SQL-ін'єкція в gallarific, яка дала 0 строк.

Кожен студент повинен написати унікальний абзац про конкретний момент під час Треку В, коли одна знахідка в машині відкрила наступний крок. Двоє студентів можуть отримати root на Kioptrix 1.2 за однією і тією ж технікою, але жодні двоє не повинні описувати свій процес міркування ідентично. Загальні фрази типу «я знайшов креденшіали в gconfig.php і зайшов у MySQL» отримають половину балів. Конкретний опис із посиланнями на унікальні артефакти (точне значення хешу, кількість рядків у sudoers до редагування, точна позиція символу в HT Editor) отримає повний бал.

Звіти, у яких блок експлойту скопійовано дослівно з готового walkthrough, отримають 0 балів за весь Трек В, незалежно від якості Треку А. Якщо ви скористалися підказкою з якогось ресурсу: назвіть джерело, перефразуйте крок своїми словами, і покажіть власні артефакти запуску.

Сценарій

Cassandra Pay той самий фінтех-клієнт, що замовляв у вашої компанії аудит паролів у Лабораторній 8 повертається через два тижні з другою задачею. Команда внутрішньої безпеки Cassandra Pay прочитала ваш звіт із попереднього аудиту і визнала корисною секцію про парольну політику. Тепер вони хочуть, щоб ви розширили роботу: припустіть, що зловмисник уже отримав непривілейований shell на одному з staging-серверів (наприклад, через успішний SSH-брутфорс із попередньої лабораторної). Що далі?

Іншими словами: клієнт хоче знати, наскільки далеко зловмисник може просунутися від моменту першого shell до повного контролю над сервером, і які саме механізми Linux роблять цей шлях коротким або довгим. Контракт явно покриває: перерахування SUID-поверхні, аналіз /etc/sudoers, експлуатацію знайдених misconfigurations у режимі proof-of-concept, і три адресні рекомендації для виправлення. Контракт явно НЕ покриває: kernel-експлойти (вони можуть впасти і зруйнувати staging), pivot на сусідні машини, exfiltration реальних даних користувачів.

Технічний brief для Треку А: Metasploitable 2, та сама VM, що у Лабораторній 8, відкритий SSH на 22 порту, ваші облікові дані msfadmin:msfadmin (стандартні; клієнт це знає). Викладач напередодні налаштував один додатковий SUID-бінарник у системі, щоб ви могли натренувати техніку. Деталі шукайте в завданні 2.2. Ви маєте право на 90 хвилин роботи з машиною, після чого потрібно скласти звіт. Жодних автоматизованих сканерів типу LinPEAS клієнт хоче, щоб ви довели, що читаєте систему власноруч.

Трек В окрема, незв'язана пропозиція від іншого клієнта тижнем пізніше. Невелика регіональна страхова компанія Ligoat Insurance проводить набір junior-пентестерів і дала вам «коробку» VM-образу: за словами її СТО, образ побудовано старшим інженером для перевірки кандидатів на здатність пройти повний ланцюг від веб-вектора до root без підказок. Жодних інших інструкцій. Ваше завдання — застосувати техніки, які ви відточили у Треку А, проти цієї машини, і повернутися зі звітом, що ви знайшли.

Технічний brief для Треку В: Kioptrix Level 1.2 з VulnHub. Завантажте .ova з посилання у метаданих лабораторної роботи. Машина слухає на портах 22 (SSH) і 80 (HTTP, Apache 2.2.8 + PHP 5.2.4 на Ubuntu 8.04). Веб-додаток використовує LotusCMS і галерею Gallarific — обидва

відомі своїми CVE. Машина вимагає, щоб ви додали `kioptrix3.com` у `/etc/hosts` вашої Kali перед першим запитом до веб-сайту, інакше частина сторінок не завантажиться. Решту ви маєте з'ясувати самостійно.

Структура роботи

Усі частини 1–3.5 (трек А) є обов'язковими для кожного студента. Частина 4 (Трек В) додаткова для тих, хто претендує на оцінку А або А+. Орієнтовний розподіл часу: 70 хвилин на Трек А і 30 хвилин на Трек В, але це не жорстке обмеження; розподіляйте час відповідно до власної стратегії.

Част.	Опис	Трек	Бали	Час
1	Розгортання та сценарне брифування	А	10	~10 хв
2	SUID-перерахування та експлуатація	А	25	~25 хв
3	Аналіз <code>sudo</code> та експлуатація знайденого правила	А	25	~20 хв
3.5	Рекомендації з конфігурації для клієнта	А	15	~15 хв
4	Kioptrix Level 1.2: міні-CTF на застосування навичок	В	25	~30 хв

Частина 1: Розгортання та сценарне брифування

(10 балів, приблизно 10 хвилин треку А)

Завдання 1.1 Перевірка середовища (4 бали)

Перш ніж запустити перший інструмент, переконайтеся, що середовище готове. У вас мають бути запущені Kali VM і Metasploitable 2 у Host-Only мережі на одній підмережі (та сама конфігурація, яку ви використовували у Лабораторній 8). Запустіть `netdiscover` або `arp-scan`, знайдіть IP-ціль, зробіть `ping`. Скріншот успішного `ping` і записаний IP — це перший артефакт у звіті.

Підключіться до Metasploitable 2 через SSH з відомими стандартними обліковими даними `msfadmin:msfadmin`. Виконайте `id`, `uname -a`, `hostname` і збережіть вивід кожної команди у звіт. `uname -a` знадобиться у завданні 2.4. Ви маєте чесно пояснити, чому ви НЕ використовуєте цю інформацію для kernel-експлойту, навіть якщо ядро 2.6.24 містить публічно відомі CVE.

Скачайте Kioptrix Level 1.2 з VulnHub за посиланням у метаданих лабораторної роботи. Імпортуйте у VirtualBox, але НЕ запускайте її зараз. Трек В у вас попереду. Просто переконайтеся, що файл `.ova` імпортувався без помилок.

Завдання 1.2 Брифування клієнта (6 балів)

У звіті напишіть короткий розділ «Brief» обсягом 150–200 слів, у якому ви викладаєте розуміння задачі від імені пентестера, який щойно отримав контракт від Cassandra Pay. Розділ має містити три частини. Перше: 2–3 речення про скоуп, із явним проговоренням того, чому kernel-експлойти виключені (підказка: ризик падіння staging, складність відкату, не входить у contract). Друге: одне речення про ваш план — що саме ви плануєте зробити в наступні 70 хвилин і в якому порядку. Третє: одне-два речення про очікуваний deliverable: що саме клієнт отримає від вас наприкінці і чим Лабораторна 9 відрізняється від Лабораторної 8.

Це не формальність. Реальний пентест-проект починається саме з такого внутрішнього brief, і відсутність чіткого формулювання задачі — найчастіша причина, чому пентестери виходять за межі дозволеного score. Особливо важливо для `privesc`: момент отримання `root` — це найгучніша подія у усьому engagement-i, і клієнт має знати, що ви цей момент явно скоупили.

Частина 2: SUID-перерахування та експлуатація

(25 балів, приблизно 25 хвилин — Трек А)

Завдання 2.1 Перерахування SUID-поверхні (6 балів)

На Metasploitable 2 у вашому SSH-сеансі виконайте канонічну команду перерахування SUID-бінарників:

```
$ find / -perm -4000 -type f 2>/dev/null
```

Команда поверне ~20–30 рядків. Збережіть повний вивід у файл `suid_inventory.txt` і додайте його у звіт як скріншот або таблицю. Підрахуйте точну кількість знайдених SUID-бінарників (`wc -l`) і зафіксуйте це число — воно знадобиться у Завданні 2.4.

Не зупиняйтесь на одній команді. Запустіть також:

```
$ find / -perm -2000 -type f 2>/dev/null      # SGID-бінарники
$ getcap -r / 2>/dev/null                    # capabilities
```

Зафіксуйте, чи знайшли ви SGID-бінарники з нестандартним патерном і чи присутні бінарники з `capabilities`. Це не оцінюється окремо, але показує, що ви читаєте поверхню повністю, а не зупиняєтесь на найочевиднішому.

Завдання 2.2 Кандидати на дослідження (5 балів)

Складіть таблицю з 4–6 SUID-бінарників із вашого виводу, які ви ВИЗНАЧИЛИ як такі, що потребують дослідження. Не вписуйте всі 25; виберіть лише ті, що відрізняються від стандартного набору Debian. Для кожного: одне речення про те, чому ви його обрали (підказка з лекції: «будь-що, що може запустити shell, відредагувати файл або виконати команду»).

Серед штатних SUID-бінарників Metasploitable 2 один має зловживну техніку у GTFOBins, яку студенти Лекції 9 повинні впізнати миттєво. Викладач також встановив один додатковий SUID-бінарник напередодні лабораторної роботи, щоб ви могли натренувати техніку на свіжому прикладі. Він не присутній у стандартному дистрибутиві Debian Etch, і його легко відрізнити за нетиповим розташуванням або іменем. Ваше завдання: знайти обидва і вписати їх у таблицю кандидатів. Якщо у вашій таблиці немає цих двох, почніть енумерацію спочатку.

Завдання 2.3 Експлуатація через GTFOBins (10 балів)

Виберіть одного з кандидатів, відкрийте <https://gtfobins.github.io>, знайдіть запис для цього бінарника та прочитайте розділ SUID. Запам'ятайте: ви читаєте техніку, а не копіюєте команду. У звіті ви маєте пояснити, ЧОМУ ця техніка працює; достатньо просто запустити її і зробити скріншот.

Виконайте техніку на Metasploitable 2. Після успішного запуску перевірте через `id`, що ваш `euid` дорівнює 0:

```
# id
uid=1000(msfadmin) gid=1000(msfadmin) euid=0(root) groups=...
```

Зверніть особливу увагу на `euid=0(root)` на тлі `uid=1000(msfadmin)`: це прапорець, що свідчить про те, що техніка спрацювала коректно. Якщо ви бачите тільки `uid=0` (без `euid`), ви забули прапорець `-p` під час запуску оболонки. Це найпоширеніша помилка студентів: оболонка запустилася, але миттєво скинула привілеї.

У звіті: точна команда GTFOBins, яку ви використали (як один рядок); точне пояснення прапорця `-p` у 1–2 реченнях; скріншот `id` з підкресленим `euid=0`; і ваш власний абзац (3–4 речення) про те, ЧОМУ цей конкретний бінарник є зловживним. Не повторюйте лекцію слово в слово, пишіть про те, як ВИ зрозуміли техніку, читаючи запис у GTFOBins.

Завдання 2.4 Аналіз і самокритика (4 бали)

Напишіть абзац (5–6 речень) про те, що цей результат говорить про SUID-конфігурацію Metasploitable 2. Ваш аналіз має відповідати на три запитання. Перше: який клас помилки конфігурації ви продемонстрували (зайвий SUID на широкому інструменті, успадкований SUID із застарілої версії дистрибутива, навмисне ослаблення для зручності)? Друге: скільки часу від

моменту першого shell до root зайняла повна послідовність (від запуску find до отримання `uid=0`)? Третє а як би ви виявили цю атаку як захисник? Ви запустили shell з підвищеними привілеями; які саме події в `auditd` мали б згенерувати алерт?

Цей абзац: головний artefact аналізу. Не пишіть загальних слів про «важливість моніторингу», пишіть конкретно: «коли я запустив [команду GTFOBins], `setuid syscall` від `UID 1000` із `target /bin/sh` мав би згенерувати правило з ключем `privesc_setuid`». Конкретність важить більше за повноту.

Частина 3: Аналіз sudo та експлуатація

(25 балів, приблизно 20 хвилин трек А)

Завдання 3.1 Читання вашого зрізу sudoers (6 балів)

На Metasploitable 2 виконайте `sudo -l`. Якщо команда запитає пароль, введіть `msfadmin` (це нормально: лекція пояснювала, чому `sudo -l` може запитувати пароль). Зафіксуйте у звіті повний вивід команди дослівно, як він прийшов з терміналу. Це ваш єдиний легітимний `read`-доступ до `/etc/sudoers` як непривілейований користувач.

Прочитайте свій зріз `sudoers` уважно. Зверніть увагу на блок `Defaults` угорі: які прапорці виставлені (`env_reset`, `secure_path`, тощо)? Це впливає на те, чи можете ви атакувати змінну середовища. Зверніть увагу на правила нижче: який список команд вам дозволено? Чи є серед них `NOPASSWD`-правило?

У звіті: повний вивід `sudo -l` як скріншот або `preformatted`-блок; ваш аналіз у 3–4 реченнях, що саме ви побачили незвичного; і одне речення про те, як саме ви плануєте експлуатувати знайдене правило.

Завдання 3.2 Експлуатація знайденого sudo-правила (10 балів)

Знайдене у завданні 3.1 `NOPASSWD`-правило надає вам право запустити певний бінарник як `root`. Якщо цей бінарник є у `GTFOBins`, використайте задокументовану техніку. Якщо ні подумайте самостійно: які можливості має цей бінарник, які з них можна використати для порушення межі привілеїв? Найчастіше відповідь у одній з трьох категорій: `-exec/--exec/system()` для виконання довільних команд; редагування файлів від імені `root` (наприклад, `/etc/passwd` або `/etc/sudoers`); запис у `root`-власний файл, який потім читає привілейований процес.

Виконайте техніку. Перевірте `id`. Зробіть скріншот. У звіті: точна команда, рядок `sudoers`, який ви експлуатували, і пояснення, ЧОМУ це правило було помилковим з точки зору адміністратора, який його написав.

Завдання 3.3 Що ще ви могли б зробити (5 балів)

Залишаючись у `root-shell`, який ви отримали в 3.2, не виконуйте жодних дій, що виходять за межі цієї лабораторної роботи. Не змінюйте паролі, не створюйте користувачів, не читайте `/etc/shadow` без нагальної потреби. Натомість зробіть невелику вправу: напишіть у звіт абзац (4–5 речень) про те, що саме ви могли б зробити з цього `root-shell` у реальному `engagement-i`, і чому ви цього НЕ робите в лабораторії. Ваша відповідь: це фактично частина `legal boundary` з лекції, але застосована до конкретної ситуації.

Завдання 3.4 Ідентифікація патерну (4 бали)

До якого з трьох патернів помилок `sudo`, які розглядалися в лекції, належить знайдене вами правило: `NOPASSWD` на широкому інструменті, шаблон у списку команд, або проблема зі змінними оточення? Напишіть 3–4 речення з обґрунтуванням. Якщо вашому правилу не пасує жодна з трьох, це теж валідна відповідь, але тоді опишіть власне, що саме у правилі робить його помилковим.

Частина 3.5: Рекомендації з конфігурації

(15 балів, приблизно 15 хвилин трек А)

Cassandra Ray чекає у звіті розділу із трьома конкретними рекомендаціями щодо посилення конфігурації серверів, заснованими на тому, що ви знайшли у частинах 2 і 3. Це не загальні поради з інтернету, а висновки з ВАШИХ результатів.

Завдання 3.5.1 Три рекомендації (10 балів)

Заповніть таблицю нижче трьома конкретними рекомендаціями. Кожна рекомендація має бути адресною (вказана конкретна система, директива чи параметр), кількісно вимірною (вказані конкретні значення або правила), і з обґрунтуванням, що посиляється на ваші ж результати з частин 2 чи 3.

#	Сфера	Рекомендація	Параметри	Що це ламає у моїй атаці
1	...	...	...	посилання на Завдання 2.X / 3.X
2	...	...	...	посилання на Завдання 2.X / 3.X
3	...	...	...	посилання на Завдання 2.X / 3.X

Приклади сфер, які доречно адресувати: SUID-мінімізація на образі ОС (з огляду на вашу таблицю кандидатів у 2.2); посилення sudoers-конфігурації (Defaults env_reset, secure_path, заборона шаблонів: з огляду на 3.1); монтування /tmp і /var/tmp з nosuid (з огляду на загальний клас атак SUID); auditd-правила для виявлення setuid syscall від не-системних UID (з огляду на ваш аналіз у 2.4); квартальний review /etc/sudoers (з огляду на те, що знайдене правило, ймовірно, було додано як зручність і не переоцінювалось).

Завдання 3.5.2 — Найкритичніша одна (5 балів)

З трьох рекомендацій виберіть одну: ту, яку ви рекомендуєте впровадити першою. Напишіть абзац (4–5 речень) з двома частинами. Перша частина: чому саме ця рекомендація має пріоритет: якби клієнт впровадив лише її, що змінилося б у його ризик-профілі. Друга частина, за яку платить бізнес: реальні незручності для адміністраторів, ризики поломки workflow, які клієнт втрачає. Без розуміння ціни рекомендація звучить як вимога; з розумінням ціни, як професійна порада, яку клієнт може реально розглянути.

ПЕРЕХІД ДО ТРЕКУ В

Якщо ви завершили Частини 1–3.5 і отримали валідні результати, ви вже маєте повний бал за Треком А (75/100). Решта документа це Частина 4, Трек В, розширення на 25 балів для оцінки А/А–.

Трек В вимагає принципово іншого підходу. Замість контрольованої вправи з тренувальним середовищем ви отримуєте VM, про яку відомо лише те, що її було побудовано для перевірки junior-кандидатів. Жодних інструкцій, жодного прямого SSH-доступу: потрібен повний ланцюг від веб-вектора до root.

Перш ніж починати Трек В, збережіть усі скріншоти та файли Треку А в окремій папці. Ви не повинні втратити докази, працюючи над новою машиною. Якщо ви плануєте здати лише Трек А пропустіть наступну сторінку і переходьте до розділу «Що здавати».

Частина 4: Kioptrix Level 1.2 — міні-CTF на застосування

(25 балів, приблизно 30 хвилин — трек B)

Kioptrix Level 1.2 — VM з VulnHub, побудована як beginner-friendly OSCP-style машина. На машині є ланцюг із чотирьох логічних кроків: веб-енумерація → RCE через CMS → знаходження облікових даних у файлі конфігурації → SSH-логін → SUID-експлуатація для root. Ваше завдання — пройти цей ланцюг до кінця і прочитати фінальний файл /root/Congrats.txt. Машина не має «прапорів» у строгому CTF-сенсі успіх вимірюється тим, чи ви прочитали Congrats.txt і чи задокументували шлях.

ЯК ОЦІНЮЄТЬСЯ ТРЕК B

Цей трек не оцінюється за фактом отримання root. Двоє студентів можуть прочитати Congrats.txt, але отримати дуже різні бали залежно від якості документації шляху. Шкала така.

20–25 балів: звіт показує всі ключові знахідки з вашими власними артефактами: точне значення MySQL-хешу для loneferret, конкретний рядок sudoers до і після редагування з вказанням позиції зміни, ваш власний абзац про момент, коли структура CompanyPolicy.README підказала вам напрям атаки.

12–19 балів: root отримано, але документація поверхнева або частково копіює walkthrough-патерни (загальні фрази без конкретних артефактів із вашого запуску).

5–11 балів отримано лише SSH-доступ як loneferret; шлях до root не пройдено; документація фрагментарна.

0–4 балів: немає доказів, що ви запускали машину; звіт виглядає, як переказ walkthrough.

Завдання 4.1 — Розгортання та веб-розвідка (5 балів)

Запустіть Kioptrix Level 1.2 у VirtualBox у Host-Only мережі (та сама конфігурація, що використовувалась для Metasploitable у Треку A; обидві машини можуть співіснувати на одній підмережі). Знайдіть IP цілі через netdiscover.

ВАЖЛИВО: перш ніж відкривати веб-сайт у браузері, додайте у /etc/hosts на Kali рядок:

```
<IP_цілі>    kioptrix3.com
```

Без цього кроку галерея на сайті не завантажиться коректно це специфіка цієї машини. Якщо ви пропустили цей крок, ви прокрутите 10 хвилин, намагаючись зрозуміти, чому /gallery повертає 500.

Виконайте сканування Nmap (-sV -p-) і зафіксуйте відкриті порти. Очікувано: 22 (SSH OpenSSH 4.7p1) і 80 (Apache 2.2.8 / PHP 5.2.4). Відкрийте сторінку <http://kioptrix3.com> у браузері. Походіть по сторінках. Зверніть увагу на нижній колонтитул — там вказана CMS-платформа, на якій працює сайт. Це ваш перший pivot до атаки.

У звіті: вивід nmap, скріншот головної сторінки kioptrix3.com, скріншот сторінки /gallery (для доказу, що /etc/hosts налаштовано правильно), і назва CMS, яку ви ідентифікували.

Завдання 4.2 — Експлуатація CMS і shell як www-data (7 балів)

Виявлений CMS має публічно відому RCE-вразливість через функцію eval(). Знайдіть exploit-script (підказка: searchsploit за назвою CMS) або використайте Metasploit-модуль

(lotus_cms_eval). Виконуйте exploit вручну — мета не у швидкості, а в розумінні. Налаштуйте reverse shell listener (nc -lvp <порт>) на Kali, запустіть exploit, отримайте shell як www-data.

Перетворіть базовий nc-shell на TTY-shell:

```
$ python -c 'import pty; pty.spawn("/bin/bash")'
```

Це не косметика — без TTY-shell багато наступних команд (sudo, vim, su) не працюватимуть.

У звіті: точний URL exploit-у або назва Metasploit-модуля, payload, який ви обрали, скріншот успішного reverse shell, вивід id як www-data.

Завдання 4.3 Креденшіали з gconfig.php і MySQL (4 бали)

Як www-data ви маєте доступ до файлів веб-додатка. Перейдіть у /home/www/kioptrix3.com/ або /var/www (точне розташування залежить від конфігурації Apache на цій машині — зчитайте /etc/apache2/sites-enabled/ якщо потрібно). Знайдіть конфігураційний файл галереї gconfig.php. Прочитайте його. Усередині будуть креденшіали для MySQL у форматі `$GLOBALS["gallarific_mysql_username"]` і `$GLOBALS["gallarific_mysql_password"]`.

З цими креденшіалами зайдіть у MySQL:

```
$ mysql -u <user> -p<password>
```

Перерахуйте бази, виберіть ту, що містить таблицю користувачів (підказка: gallery), знайдіть таблицю dev_accounts, прочитайте її. Збережіть точні значення хешу для користувача loneferret це ваш унікальний артефакт для Завдання 4.6.

Зламайте хеш через John the Ripper з rockyou (це швидко — менше хвилини, бо хеші тут MD5).

Завдання 4.4 SSH як loneferret (3 бали)

Зайдіть на машину через SSH з обліковими даними loneferret і паролем, який ви зламали. Після успішного входу прочитайте файл «CompanyPolicy».README у домашньому каталозі містить підказку щодо вектора privesc. Не пропускайте цей файл; він є частиною дизайну машини, а не випадковим артефактом.

Виконайте sudo -l. Запишіть точний рядок, який ви побачили (зокрема, чи є в ньому оклик !, який саме бінарник дозволено, і чи є NOPASSWD).

Завдання 4.5 Privesc через HT Editor (4 бали)

Sudoers-правило для loneferret дозволяє запускати /usr/local/bin/ht як root. HT Editor це hex/text editor, який, як знає кожен, хто прочитав Лекцію 9, належить до категорії «програм, що можуть редагувати файли». А якщо вона запускається як root, то може редагувати будь-що, включно з /etc/sudoers або /etc/passwd.

Запустіть sudo ht. Натисніть F3, відкрийте /etc/sudoers. Знайдіть рядок з окликом! Перед /usr/bin/su (саме оклик не дозволяє loneferret використовувати su). Замініть оклик на пробіл (це 0x20 у hex-режимі) АБО видаліть весь рядок і замініть його на loneferret ALL=(ALL) NOPASSWD: ALL. Натисніть F2 для збереження, потім F10 або Ctrl+C для виходу.

Тепер виконайте su -, введіть пароль loneferret (так — це той самий пароль, який ви зламали у 4.3, su вимагає пароль користувача-джерела). Якщо все правильно, ви root. Перейдіть у /root, прочитайте Congrats.txt.

У звіті: скріншот HT Editor у момент редагування sudoers (з підкресленою позицією, де ви робили зміну); точне значення байта до і після (наприклад, «позиція 0x4A2 — було 0x21 (!), стало 0x20 (пробіл)»); скріншот id як root; вміст Congrats.txt.

Завдання 4.6 унікальний абзац про перехід (2 бали)

Напишіть один абзац (4–5 речень) про конкретний момент під час Kioptrix 1.2, коли одна знахідка відкрила вам наступний крок. Не «я знайшов креденшіали і зайшов на MySQL». Конкретно: який саме файл, що саме у ньому вас спонукало запідозрити, що це і є цільова інформація, і коли

саме (на якому рядку коду чи на якому повідомленні від інструмента) ви побачили підтвердження. Цей абзац це ваш anti-walkthrough маркер. Якщо два студенти напишуть тут однакові речення, обидва втраять усі бали за цим завданням.

Що здавати

Єдиний звіт у форматі DOCX з усіма завданнями, скріншотами, таблицями і аналізом. Назвіть файл Lab9_Прізвище_Група.docx. Якщо ви виконали лише Трек А, зазначте на титульній сторінці звіту «Виконано: Трек А». Якщо виконали обидва — «Виконано: Трек А + Трек В». Здайте звіт до дедлайну.

Орієнтовний обсяг власного тексту: 1200–1700 слів для Треку А, додаткові 600–900 слів для Треку В. Звіт, який складається здебільшого зі скріншотів без тексту, буде оцінено за нижньою межею для кожного розділу.

Усі дії виконуються в ізолюваному середовищі Host-Only. Не скануйте машини поза межами VirtualBox. Не запускайте отримані експлойти проти жодних інших систем. Див. Розділ 6 силабусу щодо політики використання AI та академічної доброчесності.

Успіху.